**QCM** **TEST**

# Part I (For Grades F to E)
# DD2395 Computer Security
# Exam 2020-01-10, 08.00 – 11.00

*This is a closed-book exam, no material (books, articles, laptops, phones, or any other electronic devices, etc.) permitted. Questions using the sign ♣ may have zero, one or several true statements in that category. The option* None of these answers are correct *exists to detect the difference between a question with no true statements and one that has not been answered. All other options (statements) are graded individually, i.e., whether you correctly identified a statement as true (by filling in the box) or false (by leaving the box empty).*
***Mark all true statements on the separate answer sheet by COMPLETELY FILLING in the corresponding box like this: ■. Hand in your exam sorted like this: cover page, Part I: the multiple-choice answer sheet, Part II written responses.***

**Question 1 ♣** Concepts, CIA

A The main security properties (CIA) are confidentiality, integrity, and accountability.

B When system resources get corrupted, that results in a loss of integrity.

C A valid way of interpreting the principle of complete mediation is that there should not be a way around any security checks.

D *None of these answers are correct.*

**Question 2 ♣** Authentication.

A Authentication can be done by proving something you know (e.g. password), something you have (e.g. access card), something you are or do (e.g. biometrics), your location, or several of these factors together.

B As long as a chosen password is not an actual word (e.g., because it contains numbers or special characters), it is safe from an offline dictionary attack.

C Kerberos provides mutual authentication between a user and a server, i.e., not only is the user authenticated to the server but the user can be sure that the server is authentic as well.

D *None of these answers are correct.*

**Question 3 ♣** Cryptography

A With symmetric cryptography, both the sender and the receiver have the same key pairs, one for encryption and one for decryption.

B Message authentication protects against an attacker between the sender and the receiver that wants to read the message.

C The requirements for public-key (asymmetric) cryptography include that it must not be feasible to compute the private key from the corresponding public key or to infer the message given the public key (used for encryption) and the ciphertext.

D *None of these answers are correct.*

**Question 4 ♣** Memory safety

A Stack canaries are mainly used to detect corruptions of return addresses.

B A heap overflow cannot be used to alter the control flow of a program.

C Executable address space protection prevents code injection by making code non-writable and data non-executable.

D *None of these answers are correct.*

**Question 5 ♣** Malware

A An **encrypting malware** is a malware that uses encryption to make the binary of each infection unique.

B If a ransomware uses **asymmetric encryption**, then it is possible to recover the encrypted files by extracting the encryption key from the malware memory while the malware is running.

C A **secure** mechanism to detect malware is to execute unknown applications on your own computer and periodically inspect the application binary.

D *None of these answers are correct.*

**Question 6 ♣** Denial of Service

A Ingress filtering consists of the router **closest** to the victim dropping all packets coming from spoofed IPs

B A DOS can be performed by exploiting bugs of a remote program and crafting a specific input that leads the victim program to fail.

C In a TCP/IP SYN spoof attack, the attacker primarily exhausts the network bandwidth of the victim.

D *None of these answers are correct.*

**Question 7 ♣** System security

A Return Oriented Programming (ROP) and Jump Oriented Programming (JOP) are ineffective if code injection is prevented.

B Guard Pages are used to detect buffer overflows and buffer over-reads.

C Address Space Layout Randomization consists of randomizing the positions of the stack, heap, and code, hence making it difficult for an attacker to predict effects of memory errors such as buffer overflows.

D *None of these answers are correct.*

**Question 8 ♣** Access Control

A In Unix, permissions are grouped into owner (whose file it is), user (who currently is using the file), and world (everyone else).

B An access control matrix can be decomposed into access control lists (per object, who can do what to them) and capabilities (per subject, what can they do to which object)

C Access control is about authorization and needs authentication so that the authorization is meaningful.

D *None of these answers are correct.*

**Question 9 ♣** Intrusion Detection, Firewalls

A Signature-based intrusion detection can only detect intrusions that are already identified as such in the IDS.

B Firewalls may not fully protect against internal threats.

C Intrusion detection necessarily results in false positives or negatives.

D *None of these answers are correct.*

**Question 10 ♣** Side-channels

A A side-channel attack consists of injecting faults into a system (i.e. using electromagnetic waves).

B Flushing caches is sufficient to prevent attacks that measure execution time of the victim.

C Constant-time execution prevents leakage via side channels by making the control flow and memory accesses being not-dependent on secret variables.

D *None of these answers are correct.*

**Question 11 ♣** Privacy

A Privacy-enhancing technologies aim to provide properties such as anonymity, unlinkability, and deniability.

B Privacy concerns not only the data itself (e.g., contents of files or messages) but also metadata, meaning data about the data.

C *None of these answers are correct.*

**Question 12 ♣** Web Security

A SQL injections are attacker data injected into otherwise legitimate queries (SQL statements) and can be countered by using parameterized queries or object-relational mapping.

B Cross-site scripting takes advantage of a user being authenticated for a session with a server and makes it look like a transaction was initiated by the authenticated user.

C *None of these answers are correct.*

**Question 13 ♣** Social Engineering, Human Factors, Policies

A One strategy of social engineering is to create and then fix a problem.

B If enough technical countermeasures are deployed (e.g., spam filtering, unclickable links in mails), social engineers cannot succeed.

C *None of these answers are correct.*




# Part II (For Grades D to A)
# DD2395 Computer Security
# Exam 2020-01-10, 08.00 – 11.00

This is a closed-book exam, no material (books, articles, laptops, phones, or any other electronic devices, etc.) permitted. Please answer in English if you can, only answer in Swedish if you must. Hand in your exam sorted like this: cover page, Part I: the multiple-choice answer sheet, Part II: your written responses to the questions below. When numbering your pages, start with number 2 on your first handwritten page, since the multiple-choice answer sheet already is the number 1.

This part is only graded if Part I resulted in an E. Bonus points that have not been used up in the Part I of the exam (multiple choice, to get grade E) can be used as points here. The preliminary grading is as follows:

- E: 0-9 points
- D: 10-13 points
- C: 14-17 points
- B:18-21 points
- A: 22 or more points.

## 1 [C, 3 points] Denial of service.

A random program generator service $S$ allows clients to generate random data. Each client $C_i$ shares a symmetric key $K_i$ with the service. The system implements the following protocol:

- In order to ask for random data, a client $C_i$ sends the UDP message $IP_i, IP_S, X, L$ to $S$, where $IP_i$ is the IP of the client and $IP_S$ is the IP of the server, $X = E(IP_i, K_i)$ is the encryption of $IP_i$ using key $K_i$, and $L$ is the number of byte requested
- The service checks that $D(X, K_i) = IP_i$ and terminates if the check fails
- If the check succeeds, the service generates $L$ bytes of random data, splits the results in blocks of 512 KB, and sends each block $D_j$ to the client via a UDP message $IP_S, IP_i, D_j$ to $C_i$

1. Describe how this system can be abused by an attacker (that is not one of the clients) in order to perform a DOS of one of the clients $C_i$. Assume that the attacker has less bandwidth than the victim and that they cannot recover the key $K_i$ even if they can analyze the traffic.
2. Describe how this vulnerability can be countered.

## 2 [A, 5 points] Buffer overflow.

1. Write parameters for the function `main` that makes the program execute `do_something` even if `pwd <> "1234"` and `pwd <> "abcd"`
2. Explain why this happens.
3. Explain how this problem can be fixed.

```
typedef struct
{
    int i;
    int k;
} root;

typedef struct
{
    int i;
} user;


void init(int usertype, void * p) {
  if (usertype == 0) {
    user * u = (uset *)p;
    (*u).i = 0;
    return;
  }
  root * r = (root *)p;
  (*r).i = 0;
  (*r).j = 1;
}

void main(char * pwd, int usertype) {
  int authenticated = 0;
  user u;
  if (usertype == 0)
    authenticated = (strcmp(pwd, "1234") == 0);
  else
    authenticated = (strcmp(pwd, "abcd") ==  0);
  init(usertype, &u);
  if (authenticated)
    do_something(u);
}
```

**3 [A, 5 points] Hash functions.**
Let $x = x_1 \dots x_n$ be an input of $n$ blocks of 256 bits. $H(x) = SHA(x_1 \oplus \dots \oplus x_n)$ with $\oplus$ being bitwise xor, and $SHA$ the Secure Hash Algorithm 2. Is $H$ a secure hash function? For each requirement of secure hash functions, disprove the requirement or argue why the requirement is met.

**4 [A, 5 points] Authentication: Passwords.**
The passworth.com web service provider wants to make sure their users' passwords are protected. They take the following measures to do that.

1. Passwords are hashed and not stored in plain text. The hash function used has been developed and refined over several years by passworth.com experts and has been kept secret. A salt has been added (the randomly generated prime number 3,184,497,539).

2. Access rights to the stored hashes have only been given to the web server (and 3 fallback servers in case of overload or in case the primary server is down), and to a few system administrators.

3. To make sure the users have good passwords, the passworth.com admins give strict guidelines (at least 16 characters long, with at least 2 numbers, 2 special characters, and a mix of upper and lower case). They also ask the users to change their password regularly (once a month, same as the billing cycle).

4. If the password is entered incorrectly 3 times, the user account is blocked and the user needs to call the hotline and say their username to get a new password over the phone to avoid sending passwords by e-mail.

You are being hired in passworth.com's security team and are asked to evaluate their setup. Give your analysis according to the following structure and concisely. For each of the above measures, state

1. against what threats they protect,

2. what potential vulnerabilities remain or they have introduced,

3. which countermeasures, if any, you would choose instead,

4. which factors you take into account for your choice of countermeasures

**5 [C, 3 points] Side channels.**

Let a system use a shared data cache (no instruction cache) of 256 bytes, 4 lines, 64 bytes per line. The cache is directly mapped. The array M consists of 32 entries of 4 bytes. The first sixteen entries of the array are mapped to the first cache line, the second sixteen entries are mapped to the second cache line. The variables A, B, and C are secret numbers and are mapped to the third line. Finally, assume that $B$ and $C$ are smaller than 32. The victim program is the following:

```
A = M[C]
A += M[B]
```

Can an **access driven attack** (i.e. by detecting which cache line has been evicted) extract information about the variables of this program? If yes, explain the attack and describe how you can fix the program or prevent the attack; if not, motivate why this program is secure.

**6 [C, 3 points] Diffie-Hellman Key exchange.**

Alice and Bob want to arrive compute a shared secret key using the Diffie-Hellman key exchange protocol. They have already shared the prime number $q$ and a primitive root of $q$, $\alpha$. They have also chosen their private keys ($X_A$ and $X_B$, respectively) and derived the corresponding public keys ($Y_A$ and $Y_B$, respectively).

1. What do Alice and Bob send to each other?
2. How do they compute the secret key?
3. Assuming Carol can intercept messages and performs a man-in-the-middle attack. Draw the message exchange between Alice and Carol as well as between Carol and Bob.

**7 [C, 3 points] Intrusion Detection.**

As the head of security of your organization, you need to analyze the following problem. Staff in the IT department have been complaining about the new intrusion detection system InTRUEsion resulting in many false alarms.

1. What are plausible reasons (briefly explain at least two) of this excess of false positives?
2. What are plausible consequences (briefly explain two) of this many false positives?
3. Assuming that you can adapt the behavior of InTRUEsion to your environment, what would you check first (briefly explain)?